

Políticas de Seguridad DLP

Prevencion de Perdida de Datos

4Geeks Academy - Cybersecurity Bootcamp

Parte 1 - Creacion de Politicas de Seguridad DLP

1. Introduccion al Data Loss Prevention (DLP)

La Prevencion de Perdida de Datos (DLP) es un conjunto de estrategias, procesos y herramientas tecnologicas disenadas para detectar, monitorear y prevenir la exposicion, transferencia no autorizada o eliminacion de informacion confidencial dentro de una organizacion.

En el entorno digital actual, las organizaciones manejan volúmenes crecientes de datos sensibles: informacion personal de empleados y clientes, registros financieros, propiedad intelectual y secretos comerciales. La perdida o filtracion de estos datos puede generar consecuencias graves, entre ellas sanciones legales por incumplimiento de normativas como el GDPR, danos reputacionales irreversibles y perdidas economicas significativas.

El DLP actua como una capa de proteccion que abarca tres dimensiones:

- Datos en uso: informacion que se esta procesando activamente en dispositivos o aplicaciones.
- Datos en movimiento: informacion que se transfiere a traves de redes, correo o servicios en la nube.
- Datos en reposo: informacion almacenada en servidores, bases de datos o dispositivos fisicos.

2. Clasificacion de Datos

Para aplicar controles proporcionales al nivel de riesgo, la organizacion clasifica su informacion en tres categorias segun su grado de sensibilidad:

Categoria	Descripcion	Ejemplos	Proteccion
Datos Publicos	Informacion que puede compartirse libremente sin riesgo.	Comunicados de prensa, informacion del sitio web.	Basica
Datos Internos	Uso interno, no debe salir sin autorizacion.	Manuales, politicas internas, directorios.	Media
Datos Sensibles	Criticos, su exposicion causa dano grave.	PII, datos financieros, propiedad intelectual.	Alta

3. Acceso y Control

El acceso a datos sensibles se rige por el Principio del Menor Privilegio, que establece que cada usuario debe tener acceso unicamente a la informacion estrictamente necesaria para sus funciones.

Políticas de acceso:

- Control de Acceso Basado en Roles (RBAC): los permisos se asignan segun el rol del empleado.
- Autenticacion Multifactor (MFA): obligatoria para sistemas con datos internos o sensibles.
- Acceso temporal: los accesos especiales se otorgan de forma temporal y se revocan al concluir.
- Separacion de funciones: ningun empleado tiene control total sobre un proceso critico sin supervision.

Flujo de revision de permisos:

Etapa	Responsable	Frecuencia	Accion
Solicitud de acceso	Empleado / Supervisor	Cuando se requiera	Completar formulario de solicitud
Aprobacion inicial	Jefe de departamento	Inmediata	Validar necesidad y rol
Revision de seguridad	Equipo de TI	Inmediata	Verificar politicas y asignar permisos
Auditoría periodica	CISO	Trimestral	Revisar y revocar accesos innecesarios

4. Monitoreo y Auditoria

La organizacion implementa un sistema continuo de monitoreo y auditoria sobre el uso y transferencia de datos sensibles para detectar comportamientos anomalos y accesos no autorizados.

Reglas de monitoreo:

- Todo acceso a datos Sensibles queda registrado en logs con usuario, fecha, hora y accion.
- Las transferencias de archivos de gran volumen fuera de la red generan alertas automaticas.
- Los intentos de acceso fallidos repetidos disparan bloqueos y notificaciones al equipo de seguridad.
- El uso de dispositivos de almacenamiento externo debe estar restringido y registrado.

Herramientas de monitoreo:

Herramienta	Tipo	Funcion principal
SIEM (Splunk, IBM QRadar)	Monitoreo centralizado	Correlaciona eventos en tiempo real y genera alertas ante comportamientos anomalos.
DLP Endpoint (Symantec DLP)	Control de endpoints	Monitorea y bloquea transferencias de datos sensibles en dispositivos de empleados.
CASB (Microsoft Defender)	Seguridad en la nube	Controla el uso de apps cloud y detecta filtraciones a servicios no autorizados.
Logs de Active Directory	Auditoria de accesos	Registra inicios de sesion, cambios de permisos y accesos a recursos compartidos.

5. Prevencion de Filtraciones

La prevencion de filtraciones se basa en controles tecnicos y procedimientos que reducen la probabilidad de que informacion sensible salga de la organizacion de forma no autorizada.

Medidas tecnicas:

- Cifrado en reposo: datos sensibles cifrados con AES-256 en servidores y dispositivos.
- Cifrado en transito: comunicaciones protegidas con TLS 1.2 o superior.
- Control de dispositivos USB: bloqueados por defecto via politicas de grupo (GPO).
- Prevencion por email: reglas DLP que bloqueen envio de archivos sensibles sin cifrar.
- Segmentacion de red: redes separadas por nivel de sensibilidad para limitar movimiento lateral.

6. Educacion y Concientizacion

El factor humano es uno de los principales vectores de riesgo. La capacitacion continua del personal es un componente esencial de toda politica DLP efectiva.

Actividad	Audiencia	Frecuencia	Contenido
Induccion de seguridad	Nuevos empleados	Al ingresar	Clasificacion de datos, uso aceptable, politicas DLP.
Capacitacion anual DLP	Todo el personal	Anual	Actualizacion de politicas, casos reales, simulacros de phishing.

Taller tecnico	Equipos de TI	Semestral	Cifrado, gestion de accesos, herramientas de monitoreo.
Alertas y comunicados	Toda la org.	Cuando se requiera	Notificaciones ante nuevas amenazas o cambios en politicas.

Parte 2 - Implementacion de Restriccion de Dispositivos USB

La segunda parte de este proyecto consiste en la implementacion practica de politicas de restriccion de dispositivos USB en una maquina virtual Windows 10, aplicando directamente las politicas DLP definidas en la Parte 1.

Etapa 1 - Configuracion del Entorno (VirtualBox + USB)

Se habilito el soporte de dispositivos USB en la maquina virtual desde la configuracion de VirtualBox, activando el controlador USB 2.0 (OHCI + EHCI) para permitir el reconocimiento de dispositivos de almacenamiento extraible.

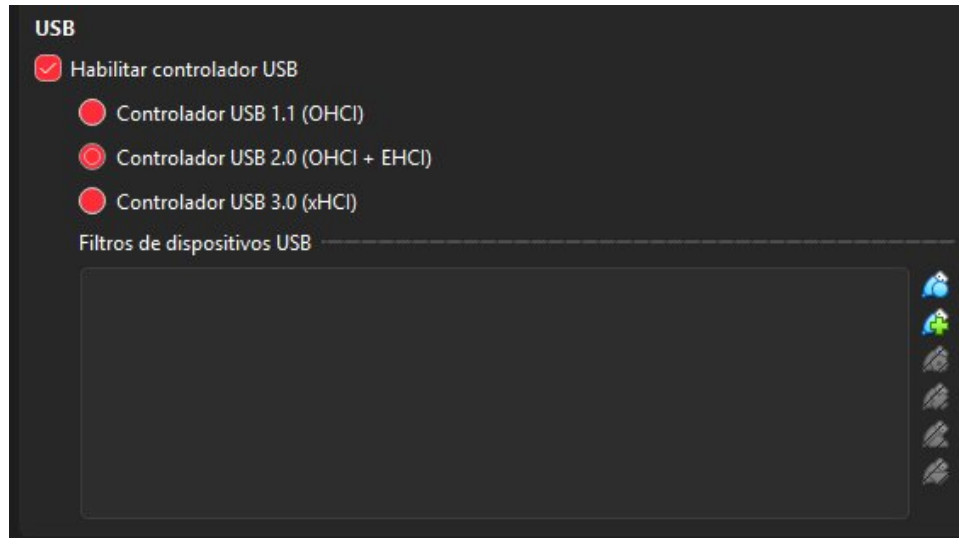


Figura 1 - Controlador USB habilitado en VirtualBox

Etapa 2 - Aplicacion de Politicas de Restriccion USB

Dado que la VM opera con Windows 10 Home, el Editor de Directivas de Grupo local (gpedit.msc) fue instalado manualmente mediante un script DISM. Una vez disponible, se navego a: Configuracion del equipo > Plantillas administrativas > Sistema > Acceso de almacenamiento extraible.

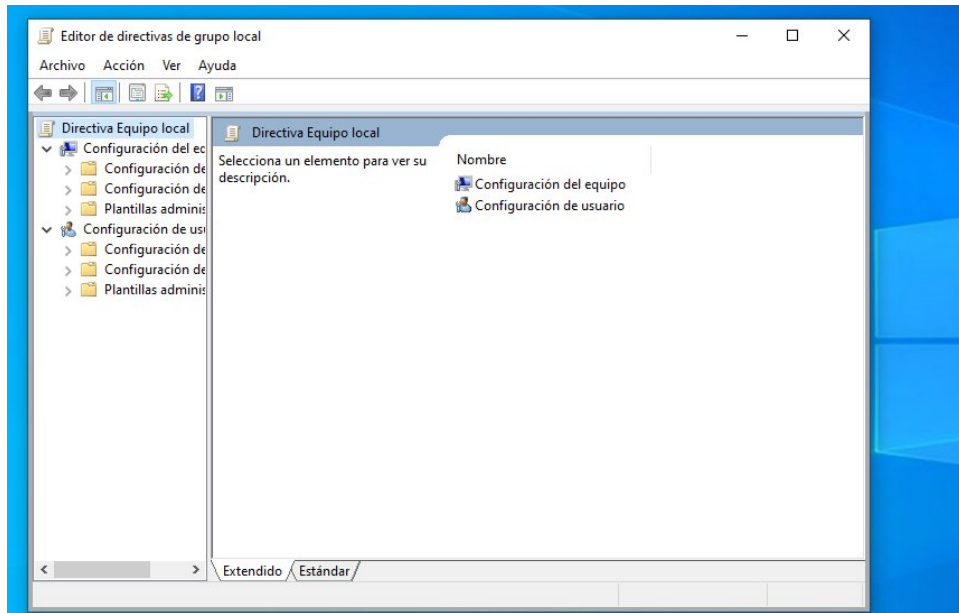


Figura 2 - Editor de Directivas de Grupo local abierto

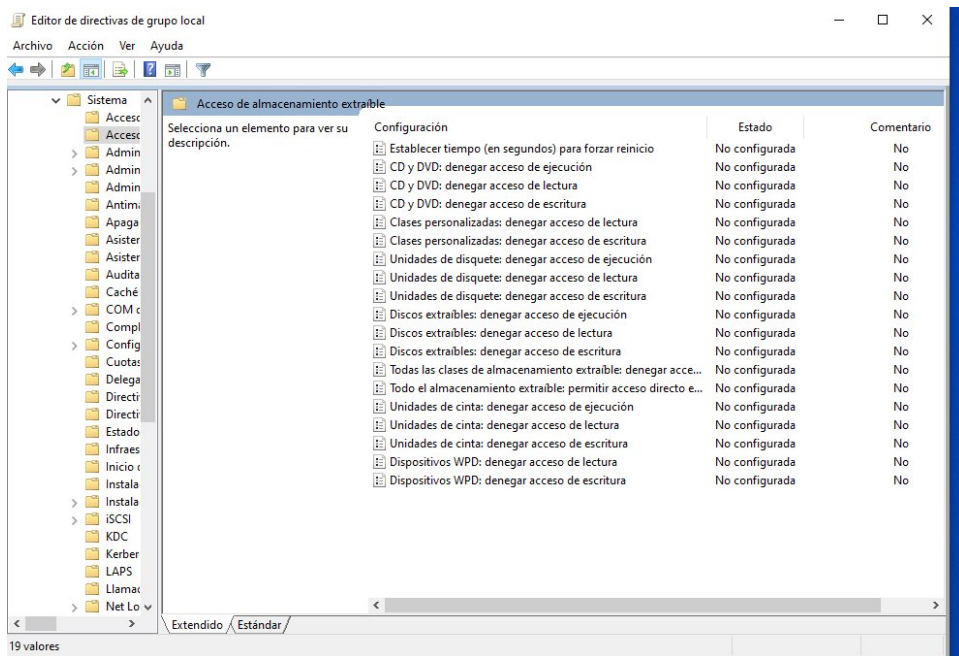


Figura 3 - Carpeta de Acceso de almacenamiento extraíble

Acceso de almacenamiento extraíble			
Discos extraíbles: denegar acceso de lectura	Configuración	Estado	Comentario
Editar configuración de directiva Requisitos: Al menos Windows Vista Descripción: Esta configuración de directiva deniega el acceso de lectura a los discos extraíbles. Si habilita esta configuración de directiva, se deniega el acceso de lectura a esta clase de almacenamiento extraíble. Si deshabilita o no define esta configuración de directiva, se permite el acceso de lectura para esta clase de almacenamiento extraíble.	☐ Establecer tiempo (en segundos) para forzar reinicio	No configurada	No
	☐ CD y DVD: denegar acceso de ejecución	No configurada	No
	☐ CD y DVD: denegar acceso de lectura	No configurada	No
	☐ CD y DVD: denegar acceso de escritura	No configurada	No
	☐ Clases personalizadas: denegar acceso de lectura	No configurada	No
	☐ Clases personalizadas: denegar acceso de escritura	No configurada	No
	☐ Unidades de disquete: denegar acceso de ejecución	No configurada	No
	☐ Unidades de disquete: denegar acceso de lectura	No configurada	No
	☐ Unidades de disquete: denegar acceso de escritura	No configurada	No
	☐ Discos extraíbles: denegar acceso de ejecución	No configurada	No
	☒ Discos extraíbles: denegar acceso de lectura	Habilitada	No
	☐ Discos extraíbles: denegar acceso de escritura	Habilitada	No
	☐ Todas las clases de almacenamiento extraíble: denegar acce...	No configurada	No
	☐ Todo el almacenamiento extraíble: permitir acceso directo e...	No configurada	No
	☐ Unidades de cinta: denegar acceso de ejecución	No configurada	No
	☐ Unidades de cinta: denegar acceso de lectura	No configurada	No
	☐ Unidades de cinta: denegar acceso de escritura	No configurada	No
	☐ Dispositivos WPD: denegar acceso de lectura	No configurada	No
	☐ Dispositivos WPD: denegar acceso de escritura	No configurada	No

Figura 4 - Políticas de denegación de lectura y escritura habilitadas

Dado que la instalación manual de gpedit no escribía correctamente en el registro, las políticas se aplicaron directamente mediante comandos de registro (reg add), garantizando que las restricciones quedaran activas en el sistema:

```
HKLM\SOFTWARE\Policies\Microsoft\Windows\RemovableStorageDevices\{53f5630d-b6bf-11d0-94f2-00a0c91efb8b}
```

```
Deny_Read = 1 | Deny_Write = 1
```

Etapa 3 - Creacion de Usuario Estandar y Prueba

Se creo un usuario estandar (usuario2) sin privilegios administrativos desde Configuracion > Cuentas > Familia y otros usuarios, seleccionando la opcion de cuenta local sin cuenta de Microsoft.

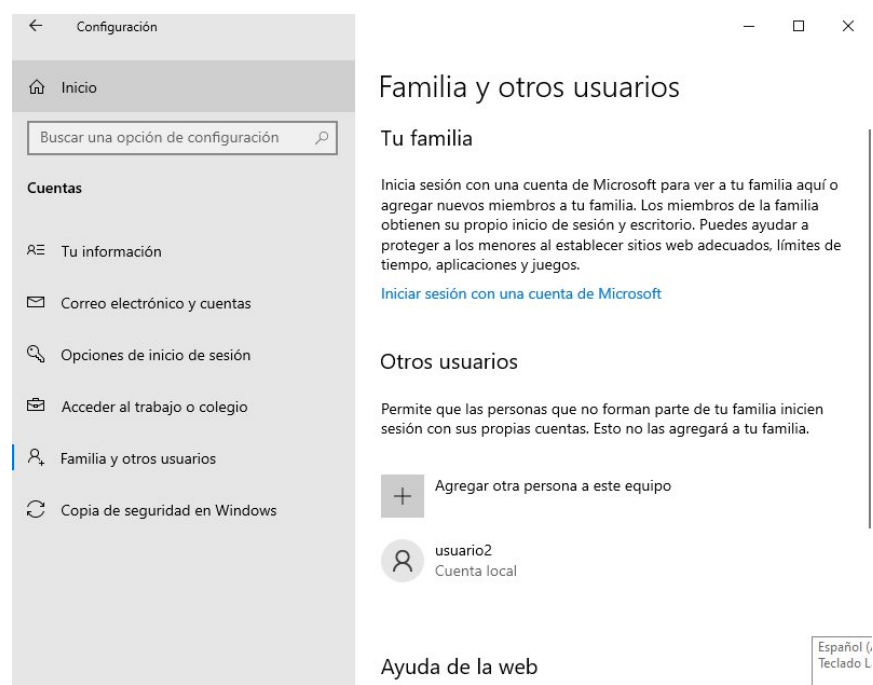


Figura 5 - Usuario estandar 'usuario2' creado correctamente

Las politicas de restriccion aplicadas via registro afectan a todos los usuarios estandar del sistema (HKLM), mientras que el usuario administrador mantiene acceso completo a dispositivos de almacenamiento extraible.

Etapa 4 - Excepcion para Usuario Administrador

Se habilito una excepcion para el usuario administrador (vboxuser) escribiendo valores en la clave HKCU (perfil del usuario actual), lo que anula la restriccion global de HKLM unicamente para dicho usuario:

```
HKCU\SOFTWARE\Policies\Microsoft\Windows\RemovableStorageDevices
Deny_Read = 0 | Deny_Write = 0
```

```
C:\Windows\system32>reg query "HKCU\SOFTWARE\Policies\Microsoft\Windows\RemovableStorageDevices" /s
HKKEY_CURRENT_USER\SOFTWARE\Policies\Microsoft\Windows\RemovableStorageDevices\{53f5630d-b6bf-11d0-94f2-00a0c91efb8b}
Deny_Read    REG_DWORD    0x0
Deny_Write    REG_DWORD    0x0
```

Figura 6 - Verificacion de excepcion para el administrador (Deny_Read=0, Deny_Write=0)

Resumen de Configuracion Aplicada

Configuracion	Detalle	Estado
Soporte USB en VirtualBox	Controlador USB 2.0 (OHCI + EHCI) activado	Completado
Politicas de restriccion	Deny_Read=1 y Deny_Write=1 en HKLM	Completado
Usuario estandar	usuario2 creado sin privilegios administrativos	Completado

Excepcion administrador	Deny_Read=0 y Deny_Write=0 en HKCU	Completado
Verificacion	Confirmado via reg query en ambas claves	Completado